

Test Report — The admin identity (`ADMIN_EMAILS`)

PR: kuantorflow#172 (+ kuantorflow_automation#34) · Issue: kuantorflow#158 · Date: 2026-08-02

Summary

The app can now tell that the signed-in visitor is an administrator, resolved from `ADMIN_EMAILS` in `.env` against Google's **verified** email claim. Nothing uses the privilege yet — #126 (blocking) and #162 (deleting any card) are what will ask — so verification concentrates on the resolution itself, which has to be right before anything is built on it.

What changed

- `app._admin_emails()` parses `ADMIN_EMAILS` into a lowercased frozenset; `ADMIN_EMAILS` is resolved once at import, beside `ACCESS_KEYWORD`.
- `app.is_admin()` next to `_current_email()`, **failing closed** on all three conditions: signed in, `email_verified` true, address listed.
- `app._email_verified()` reads Google's claim **strictly** — it is a real bool in the ID token but a string in some userinfo responses, and `bool("false")` is True. Anything unrecognised counts as not verified.
- The OAuth callback stores `email_verified` in the session, since `is_admin()` resolves from the session and had nothing to insist on otherwise.
- `inject_auth()` exposes `is_admin`, so admin-only UI will be a plain `{% if is_admin %}`.
- `.env.example` documents the variable with an empty value.

Why configuration rather than a column

The admin's job is to block other accounts, so admin-ness must not live in the table the blocking flow edits, where a bug in that flow, a stray UPDATE or a restored backup could reach it. In `.env` it sits beside `SECRET_KEY` and `ACCESS_KEYWORD`. It also avoids the bootstrap problem: the first admin has no users row until they sign in.

Automated tests

- **Added:** `tests/test_admin_identity.py` — 32 tests, in five groups: parsing (one address, several, whitespace, mixed case, empty, whitespace-only, , , , , variable unset); who resolves as admin (listed, unlisted, anonymous, one of several, none configured, case and whitespace in the *session's* email); the verified-email requirement, including a session predating the claim; the claim read strictly across `True/False/"true"/"True"/"false"/""/None/"yes"`; that the real sign-in callback stores it; and that `is_admin` reaches templates, both via `render_template_string` and through the real `inject_auth()` on a rendered page.
- **Suite result:** `pytest -m "not live"` — **273 passed** (was 241), 1 skipped, 6 deselected.

- **Mutation check:** removing the `email_verified` requirement from `is_admin()` makes **exactly two** tests fail — `test_an_unverified_address_never_matches` and `test_a_session_without_the_claim_is_not_an_admin`. The requirement is pinned, not incidentally true.

Manual & browser verification

No browser verification: #158 adds no UI by design. Checked in the app's own request context after configuring the real local `.env`.

- `ADMIN_EMAILS=anton.kuznietsov@gmail.com` added to the local `.env` → the app parses it to `['anton.kuznietsov@gmail.com']`.
- Session with that address and `email_verified: True` → `is_admin()` **True**.
- Same session **without** the `email_verified` key (the shape of every session created before this change) → `is_admin()` **False**, confirming the fail-closed path on real configuration rather than only in tests.
- `.env` confirmed gitignored (`.gitignore:41`), so no address reaches the repository.

Result

Pass. All acceptance criteria in #158 met.

Worth knowing at deploy time: storing `email_verified` changes the session shape, so an existing session carries no claim and its owner is **not** admin until they sign in again — on the live site as well as locally. Failing closed was chosen deliberately over granting the privilege on an unverified assertion, or continuing to grant it after an address stops being verified.

This is the third change in a row where a stored structure gained a field and the old shape had to be handled: the session gained `id` (#89), the widget state gained `identity` (#170), and the session now gains `email_verified`. In each case the old shape read as a *valid* new one rather than as missing, which is why none of them failed loudly.